

Technické mezery a rizika

Stav zdrojového kódu · commit fdae9dfba72614e42db0faf1e7c267f79f269ae8 (fix/audit-findings-2026-09-22, 26. 9. 2026)

Slovník: úklidník = „Zhotovitel“ (VOP, RS, RŘ, Kodex) = Employee (kód) = „uklízeč“ (UI); zákazník = „Zákazník / Spotřebitel / Uživatel“ = User ; host = zákazník bez účtu (Order.UserId = null); provozní společnost = „Provozovatel / Cleansia s.r.o.“ = Tenant ; administrátor = Administrator / Manager / Support / Accountant .

Závažnost: **kritická** = ztráta peněz, porušení právní povinnosti nebo únik údajů jiné osoby možné dnes; **vysoká** = totéž v reálném scénáři vyžadujícím rozhodnutí; **střední** = chybné chování, malá oprava; **nízká** = hygiena, mrtvý kód.

Deset mezer

#	mezera	proč	závažnost	citace	→ Rn / oprava
1	Automatické storno bez úklidníka vrací kredit zaplacené kartové objednávky dvakrát	zákazník dostane CreditAppliedAmount navíc přes ReturnUnpaidOrderCreditAsync	kritická	CancelUnfilledOrders.cs:195	ReturnUnpaidOrderCreditAsync jen ve větvi bez refundace (else jako PlatformOrderCancellation)
2	Fiskální položky vynechávají doplňky, slevy a expresní příplatek	fiskální součet nemusí odpovídat platbě	vysoká	ReceiptService.cs:368	→ R21
3	Administrátorské dokončení nespouští výpočet odměny	úklidník bez výplatního řádku	vysoká	AdminOverrideOrderStatus.cs:143	výpočet odměny i z override
4	Chargeback webové kartové platby nenajde objednávku	spor ani upozornění administrátora nevznikne	vysoká	HandlePaymentNotification.cs:463	PaymentIntent i z webového Checkoutu
5	Refundace nemá dobropis	účetní návaznost mimo aplikaci	vysoká	Refund.cs:18	→ R1
6	Právní seed obsahuje neschválené návrhy	souhlasy nad návrhem	vysoká	cs.md:5	→ R3
7	Administrátor přiděluje bez kontroly schválení úklidníka	neověřený člen posádky	vysoká	AdminReassignOrder.cs:74	→ R11.6

#	mezera	proč	závažnost	citace	→ Rn / oprava
8	Administrátor nemá druhý faktor	heslo chrání celý operátorský účet	vysoká	User.cs:14	2FA administrátora
9	Cookie lišta mění obecné a e-mailové souhlasy	klik má širší účinek než cookies	vysoká	consent-sync.service.ts:39	→ R9
10	Hotovost nemá inkaso storna ani odpočet vybrané hotovosti ve výplatě	vybranou tržbu drží úklidník, žádná složka od BasePay po DeductionPay ji nezapočte	vysoká	OrderEmployeePay.cs:38-46	→ R6

1. Bezpečnost

pravidlo	jedna věta	citace
S1 UserId is server-truth	Identita se čte z JWT claimu <code>NameIdentifier</code> , nikdy z těla; anonymní zápis jmenuje trh, server mapuje přes <code>SetTenantOverride</code>	UserSessionProvider.cs:29-32; OperatorTenantScopeBehavior.cs:53-69
S2 Authorization on every endpoint	Výchozí politika <code>RequireAuthenticatedUser</code> na všech pěti hostech; test odmítne admin akci bez <code>[Permission]</code> mimo <code>AllowList</code>	ServiceExtensions.cs:44-47; AdminHostPermissionCoverageTests.cs:62-66
S3 Resource-by-id ownership	<code>CanAccessOrderAsync</code> vrací true jen vlastníkovi, přiřazenému úklidníkovi nebo administrátorovi; zákazník čte přes <code>GetQueryableForOwner(userId)</code>	OrderAccessService.cs:64-95; OrderAccessService.cs:38-44
S4 DTO leak prevention	<code>OrderPiiRedaction.RedactForBrowsingCleaner</code> nuluje jméno, e-mail, telefon, adresu a instrukce pro prohlížečícího úklidníka; test drží seznam <code>DetailBlanked</code>	OrderPiiRedaction.cs:40-67; OrderRedactionSurfaceTests.cs:34-42
S5 Rate limiting	Politiky <code>auth</code> anonymně 10/min/IP, přihlášeně 30/min, <code>interactive</code> 60/min, <code>webhook</code> 60/min, strop 20 000 anonymních/min; <code>KnownUncovered</code> prázdný	RateLimitPolicies.cs:43-51; RateLimitCoverageGuardTests.cs:142-144
S6 Logging hygiene	<code>SafeBody</code> rediguje <code>SensitiveFieldRegex</code> a <code>ContactIdentityFieldRegex</code> ; cesty z <code>IsSensitivePath</code> potlačeny celé; test padne na neredigovaném DTO	RequestLoggingMiddleware.cs:197-210; RequestLogPiiSurfaceGuardTests.cs:98-103

pravidlo	jedna věta	citace
S7 Idempotency	Webhook Stripe: HasProcessedAsync(stripeEvent.Id) před účinky; refundace drží unikátní RefundKey, kolize 23505 = existující řádek	HandlePaymentNotification.cs:158- 173; RefundService.cs:97-118
S8 Tenant isolation	Globální EF filtr (SetQueryFilter) e.TenantId == currentTenantId ; CommitAsync razítkuje TenantId a odmítne zápis do zmrazené společnosti	CleansiaDbContext.cs:357-378; CleansiaDbContext.cs:104-118
S9 Migration & DTO-contract safety	Jediná migrace Initial ; test drží 49 razítkovaných tabulek (StampedTables) s FK _Tenants_TenantId a NOT NULL mimo dvě obálkové (EnvelopeTables); TenantId je cizí klíč do Tenants	InitialMigrationTenantDdlTests.cs:24- 25; TenantIdRequiredModelTests.cs:15- 16
S10 Soft-delete / IsActive	Bez globálního filtru; čtenář filtruje sám, např. Where(s => s.IsActive) u uložených adres	SavedAddressRepository.cs:18
S11 Mobile session wipe	Android clearSessionCaches() při vynuceném 401; iOS SessionScopedCacheRegistry.clearAll() při odhlášení i zamítnutém refreshi	AuthAuthenticator.kt:116-119; SessionScopedCache.swift:19-31
S12 Stored artifact disclosure	Roster ExpectedIntakes 17 upload tras, 15 z nich s pravidlem obsahu (dvě BlobFileSize only); ImageMetadata.Scrub(byte[]) vybírá walker podle bytů, nic nedekóduje	UploadIntakeRosterTests.cs:39-60; ImageMetadata.cs:35-57

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Přeřazení administrátorem ověří jen EmployeeNotFound a EmployeeAlreadyAssig nedToOrder ; schválení (EmployeeNotApproved) , které převzetí vyžaduje, ani měnu úklidníka nečte	AdminReassignOrder. cs:74-87; TakeOrder.cs:80-85	zákazník / společnost	vysoká	→ R11.6
Administrátor bez druhého faktoru: jen heslo, limit 10/min/IP, lockout 5×/15 min	rg -n "TwoFactor Totp Mfa" src/ → 0; User.cs:14- 17	společnost	vysoká	2FA administrátora

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Zákaznický a partnerský web neinstalují AddUserRevocationEnforcement ani AddDeviceRevocationEnforcement ; jejich přístupový token 1440 min platí i po resetu hesla	UserRevocationServiceExtensions.cs:13-21; appsettings.Production.json:20	zákazník / úklidník	střední	revokace na webových hostech
Deaktivace odmítá přihlášení i refresh úklidníka; již vydané přístupové JWT nemají kontrolu společnosti při každém požadavku	RefreshToken.cs:102; CompanySignInGate.cs:27	společnost	střední	kontrola společnosti na přístupovém tokenu
Přiřazený úklidník čte adresu a instrukce i po dokončení; první čtení neprázdných instrukcí se audituje, přístup časově neomezuje	OrderAccessService.cs:94; GetOrderDetails.cs:163	zákazník	střední	→ R8
Registrace (ExistingUserWithEmail) i reset hesla (NotExistingUserWithEmail) prozrazují existenci e-mailu anonymnímu volajícimu	Register.cs:42-44; RequestPasswordChange.cs:46-48	zákazník	nízká	neutrální odpověď
DEV nasazení Logging__LogLevel__Console__Information ; RequestLoggingMiddleware pod ní spadá, těla požadavků jdou do App Insights	main.bicep:541; RequestLoggingMiddleware.cs:7-9	všichni (DEV)	nízká	úroveň Warning i v DEV
Mapbox veřejný token pk.eyJ ve 4 commitech historie; ve stromu jen placeholder runbooku	git log -S "pk.eyJ" --oneline -- src deploy → 4; AZURE-DEV-RUNBOOK.md:324	společnost	nízká	rotace tokenu

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Heslo lokálního Postgresu (<code>Host=localhost</code>) v trackovaném <code>local.settings.json</code>	<code>local.settings.json:27</code>	společnost	nízká	user secrets místo souboru
Nenasazená PRO konfigurace: veřejný endpoint (<code>publicNetworkAccess</code>) zapnut, <code>privateNetworkingEnabled</code> zakomentován; <code>AllowAllAzureServicesAndResources</code> (0.0.0.0) použít provoz ze služeb Azure	<code>postgres.bicep:144-151</code> ; <code>weu.prod.bicepparam:64-68</code>	společnost	střední	privátní síť
Konfigurace připojení používá administrátor serveru <code>cleansia_admin</code> s <code>Trust Server Certificate=true</code>	<code>derivedSecrets.bicep:48</code> ; <code>weu.prod.bicepparam:74</code>	společnost	střední	aplikační role; ověření certifikátu
CI neprovádí audit zranitelnosti; dva npm manifesty mají <code>security-updates</code> skupiny, měsíční plán a <code>open-pull-requests-limit: 0</code> pro verzovací PR	<code>dependabot.yml:30</code> ; <code>dependabot.yml:46</code>	společnost	střední	audit závislostí v CI
API hosty ani zákaznický SSR nenastavují HSTS ani CSP; partnerský a admin SWA nesou <code>globalHeaders</code> <code>X-Content-Type-Options</code> , <code>X-Frame-Options</code> , <code>Referrer-Policy</code>	<code>rg -n "UseHsts Content-Security-Policy helmet" src --glob "*.cs" --glob "*.ts" → 0</code> ; <code>staticwebapp.config.js</code> <code>on:12-15</code>	všichni	nízká	bezpečnostní hlavičky
Fotky interiéru se vydávají SAS odkazem (<code>GenerateSasUri</code>) s platností 1 h — přeposlatelný nositelský odkaz	<code>GetOrderPhotos.cs:117</code>	zákazník	nízká	→ R7

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Bez virového skenu nahraných souborů; jen magic-byte <code>AcceptedByIntake</code>	rg -in "clamav antivirus malware" src --glob "*.cs" → 0; <code>SniffedContentType.cs:70-87</code>	společnost	nízká	AV sken uploadů
161 tenant-ignorujících výskytů, z toho 113 v repozitářích, bez samostatného rosteru; každý vyžaduje doložení vlastnického omezení	rg pro <code>IgnoreQueryFilters()</code> / <code>GetQueryableIgnoringTenant()</code> v Database, AppServices, Functions a Functions.Core; <code>OrderRepository.cs:248</code>	společnost	střední	roster výjimek tenantového filtru
Hesla s 10 000 iteracemi (LegacyIterations) jsou platná vedle 600 000; povýšení umí jen <code>NeedsRehash</code> , které nikdo nevolá	rg -n "NeedsRehash" src --glob "*.cs" → 1 deklarace + 1 test; <code>PasswordExtensions.cs:9-14</code>	zákazník / úklidník	nízká	povýšení hashe při přihlášení

2. Peníze a účetnictví

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
<code>CancelUnfilledOrders</code> u zaplacené kartové objednávky vrátí kredit v refundaci (<code>ReturnCreditShareAsync</code>) a znovu <code>ReturnUnpaidOrderCreditAsync</code> pod jiným klíčem: $2 \times \text{CreditAppliedAmount}$	<code>CancelUnfilledOrders.cs:195-196</code> ; <code>RefundService.cs:173</code>	společnost	kritická	<code>ReturnUnpaidOrderCreditAsync</code> jen ve větvi bez refundace (<code>else</code> jako <code>PlatformOrderCancellation</code>)

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Kredit vymazanému zákazníkovi <code>TryReturnAsync</code> nevrátí, ale vrátí stejně <code>false</code> jako opakovaný klíč; <code>ReturnCreditShareAsy nc</code> zapíše jen <code>LogInformation</code> bez důvodu	<code>CreditAccountReposit ory.cs:104-113;</code> <code>RefundService.cs:290- 294</code>	společnost	nízká	rozlišený výsledek návratu
Fiskální položky (<code>BuildFiscalLineItem s</code>) jen služby a balíčky — bez extras, slev a příplatku; účinek je latentní, dokud je fiskalizace vypnutá	<code>ReceiptService.cs:368- 392</code>	společnost	vysoká	→ R21
Bez dobropisu při refundaci; refund je jen řádek <code>Refund</code> a stav objednávky	<code>rg -in "creditnote credit_not e dobropis" src --glob "*.*" → 0;</code> <code>Refund.cs:81</code>	zákazník / společnost	vysoká	→ R1
Číslo účtenky <code>RCP- {rok}-{NNNN}</code> (<code>ReceiptNumberFormat</code>); při <code>FiscalEnforcementMod e.None</code> vrátí <code>FiscalSequenceScope NoAnnualResetYear</code> — pořadí pokračuje přes roky	<code>ReceiptService.cs:62- 66;</code> <code>FiscalSequenceScope. cs:22-27</code>	společnost	střední	roční reset číselné řady
Administrátorský přepis na <code>Completed</code> neposílá <code>CalculateOrderPayMes sage</code> — úklidník bez odměny	<code>rg -n "CalculateOrderPayM essage(" src/ → mimo testy a deklaraci jen CompleteOrder.cs:35 3 ;</code> <code>AdminOverrideOrder Status.cs:141-147</code>	úklidník	vysoká	výpočet odměny i z override
Vratka s <code>IsFailure</code> vrací chybu a spor neuzavírá; při úspěchu <code>Resolve</code> ukládá požadovaný refund, který se může lišit od skutečného	<code>ResolveDispute.cs:94;</code> <code>ResolveDispute.cs:102</code>	zákazník	střední	→ R10

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Chargeback webové kartové objednávky hledá jen <code>StripePaymentIntentId</code> , web ukládá jen <code>AssignStripeSessionId</code> ; spor ani upozornění administrátora nevznikne	<code>HandlePaymentNotification.cs:463-467;</code> <code>OrderPaymentDispatcher.cs:66</code>	společnost	vysoká	<code>PaymentIntent</code> i z webového Checkoutu
Prohraný chargeback jen zavře spor (<code>DisputeStatus.Closed</code>); <code>PaymentStatusPaid</code> se nemění, bez refund řádku, bez dopadu na odměnu	<code>HandlePaymentNotification.cs:604-609;</code> <code>rg -n "OrderEmployeePay" src/Cleansia.Core.App Services/Features/Payments/HandlePaymentNotification.cs → 0</code>	společnost	vysoká	chargeback jako pohyb peněz
<code>Refund.StripeRefundId</code> vždy null; id refundu ze Stripe se neukládá	<code>RefundService.cs:170</code>	společnost	střední	uložení <code>StripeRefundId</code>
Storno u hotovosti zapisuje <code>FeeRate</code> 25/50 % přes <code>order.Cancel</code> ; refund běží jen pro <code>PaymentType.Card</code> ; inkaso poplatku neexistuje	<code>CustomerOrderCancellation.cs:50;</code> <code>CustomerOrderCancellation.cs:102-106</code>	společnost	vysoká	→ R6
Vybraná hotovost se nezapočítává proti odměně: složkami jsou <code>BasePay</code> , <code>ExtrasPay</code> , <code>ExpensesPay</code> , <code>BonusPay</code> , <code>DeductionPay</code> ; lhůta odvodu neexistuje	<code>rg -rn "CashCollected SettledInCash" src/Cleansia.Core.App Services/Features/EmployeePayroll → 0;</code> <code>OrderEmployeePay.cs :38-46</code>	společnost	vysoká	→ R6
Potvrzení opakované hotovosti zapíše <code>PaymentStatus.Paid</code> a účtenku před inkasem; <code>MarkCashCollected</code> pak odmítne, takže převzetí nemá záznam kdo a kdy	<code>ConfirmRecurringOrder.cs:169-177;</code> <code>MarkCashCollected.cs :85-91</code>	společnost	vysoká	záznam inkasa i u opakované hotovosti

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Po ověření u Stripe, že karta nezaplacená, <code>MarkCashCollected</code> zapíše hotovost i na kartové hostovské či vícečlenné zakázce; <code>AllowsCash</code> nechte	<code>MarkCashCollected.cs:24-27</code> ; <code>git grep -n "AllowsCash" src/Cleansia.Core.App Services/Features/Orders/MarkCashCollected.cs</code> → 0; <code>BookingPolicy.cs:147</code>	společnost	střední	<code>AllowsCash</code> v <code>MarkCashCollected</code>
Plus plány <code>PLUS_MONTHLY</code> i <code>PLUS_YEARLY</code> (DEV seed, <code>FreeCancellationWindowHours</code> 4) nikdy neplatí 25 %, jen zdarma nebo <code>LastMinute</code> 50 %	<code>BookingPolicy.cs:359-366</code> ; <code>insert_seed_data.sql:1805-1822</code>	zákazník	střední	→ R4
Fiskalizace vypnuta (<code>Fiscal:CzechEet2:Enabled=false</code>); <code>CzechEet2FiscalService</code> je stub, výchozí <code>NoOpFiscalService</code>	<code>appsettings.json:85</code> ; <code>CzechEet2FiscalService.cs:8-12</code>	společnost	střední	→ R21
Jedna konfigurace <code>Stripe:SecretKey</code> bez směřování na účet jednotlivé společnosti; vlastnictví Stripe účtu kód nedokládá	<code>StripeClient.cs:34</code> ; <code>rg -n "StripeAccount OnBehalfOf TransferData" src/Cleansia.Core.App Services src/Cleansia.Infra.Clients</code> → 0	společnost	střední	→ R2
Období lze znovu otevřít, není-li <code>Paid</code> ; faktura se generuje bez ohledu na stav období (<code>PayPeriodId</code> jen <code>ExistsAsync</code>)	<code>ReopenPayPeriod.cs:40-44</code> ; <code>GenerateInvoice.cs:42-47</code>	úklidník / společnost	střední	brána stavu období
Úprava částek faktury (<code>UpdateAmounts</code>) PDF nepřegeneruje, vydané PDF nese starou částku; přegenerování je samostatný příkaz s <code>LanguageCode</code>	<code>UpdateInvoiceAmounts.cs:57-77</code> ; <code>RegenerateInvoicePdf.cs:59</code>	úklidník	střední	→ R18

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Hromadné mzdové sazby (BulkCreateEmployeePayConfigs) výchozí Math.Round (ToEven); výpočet mzdy sčítá basePay a extrasPay bez zaokrouhlení	BulkCreateEmployeePayConfigs.cs:140-141; PayCalculatorExtensions.cs:43-48	úklidník	nízká	jednotné zaokrouhlení
DEV firemní údaje mají IČO 12345678 a zástupný účet; CompanyFields neplátci DIČ netiskne	insert_seed_data.sql:161; DefaultReceiptLayoutBuilder.cs:142	zákazník / společnost	střední	→ R2
Swap plánu maže lokální CancelledAt, ale SubscriptionUpdateOptions cancel_at_period_end neruší; předplatné na Stripe dál končí	UserMembership.cs:302-304; StripeClient.cs:368-379	zákazník	střední	zrušení cancel_at_period_end při swapu
„First-order“ promokód (maxRedemptionsPerUser 1) nekontroluje, zda jde o první objednávku	RequestPromoCode.cs:84-91	společnost	střední	kontrola první objednávky

3. Data a retence

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Sdílená adresa se při výmazu nahrazuje anonymní kopií; cizí reference vložená před smazáním původního řádku může výmaz odmítnout přes FK	GdprDeletionService.cs:526-527; OrderEntityConfiguration.cs:38	zákazník	nízká	opakování výmazu při souběhu
Výmaz neodstraní samostatný řádek Address, pokud na něj neodkazuje objednávka ani profil úklidníka	GdprDeletionService.cs:382-384; GdprDeletionService.cs:527	zákazník	střední	→ R9

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
<code>GetOwnOrdersByPhoneN</code> <code>umberAsync</code> aktualizuje jen vlastní objednávky; zápis do objednávky zmrazené společnosti může odmítnout <code>CompanyArchivedExcep</code> <code>tion</code>	<code>OrderRepository.cs:13</code> ; <code>CleansiaDbContext.cs:</code> 175	zákazník	střední	→ R9
Retenční sweep anonymizuje jen objednávky s historií <code>Completed</code>; zrušené a nesplněné se neanonymizují nikdy	<code>DataRetentionBackgr</code> <code>oundService.cs:180-</code> 183	zákazník	střední	sweep i pro zrušené
Fotky dokončených zakázek mají výchozí okno 7 dní; otevřený spor brání sweepu. Výmaz účtu používá odlišný chybný parser blobové cesty	<code>OrderPhotoRepositor</code> <code>y.cs:39;</code> <code>GdprDeletionService.</code> <code>cs:546</code>	zákazník	střední	→ R7
<code>DeleteOrderPhoto</code> bez <code>[AuditAction]</code> a bez brány na stav zakázky (jen <code>AssignedEmployees.An</code> <code>y</code>); smaže i fotografii „po“, na níž dokončení stálo	<code>DeleteOrderPhoto.cs:</code> 12; <code>DeleteOrderPhoto.cs:</code> 56-71	zákazník / společnost	střední	→ R7
<code>DefaultAdminAuditRet</code> <code>entionYears</code> i výchozí okno úklidníků jsou 3 roky; rozsah nastavení je 1–100 let (<code>MaxYears</code>). Archiv má samostatnou politiku	<code>RetentionDefaults.cs:</code> 30; <code>TenantSettingCatalog.</code> <code>cs:105</code>	úklidník / společnost	nízká	→ R9
<code>AnonymizeCustomerDat</code> a ponechává <code>CustomerFloor</code> a <code>CustomerApartment</code>	<code>Order.cs:974</code>	zákazník	střední	→ R9

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
RevokeAsync odvolává tokeny hosta v CancelGuestOrder a při výmazu; ostatní storna nemají společný krok revokace	CancelGuestOrder.cs: 61; GdprDeletionService. cs:398	zákazník	střední	→ R5
Receipt worker a fiskální retry mohou vydat token i anonymizované hostovské objednávce; issuer ověřuje jen nepřítomnost účtu	GuestOrderAccessTok enIssuer.cs:31	zákazník	střední	→ R9
Dokumenty úklidníka (PDF a Office) ImageMetadata nescrubuje; administrátor je stahuje (DownloadEmployeeDoc ument) i s metadaty autora	ImageMetadata.cs:28 -31; AdminEmployeeDocu mentController.cs:93- 99	úklidník	nízká	scrub dokumentů, nebo popis v DPA
Právní texty s bannerem Návrh – toto znění zatím neprošlo právní kontrolou seeduje LegalDocumentSeedHos tedService při každém startu v každém prostředí	LegalDocumentSeed HostedService.cs:16- 20; cs.md:5	společnost	vysoká	→ R3
Souhlas úklidníka s podmínkami odkazuje na žádný text (document: null); dokument LegalDocumentAudience.Employee neexistuje	RegisterEmployee.cs: 121-126; LegalSeedResource.cs :28	úklidník / společnost	vysoká	→ R3
Admin příkaz na novou verzi právního dokumentu neexistuje; AdminLegalController r jen čte (CanViewLegalDocumen ts)	rg -rn "ICommand<" src/Cleansia.Core.App Services/Features/Leg al → 0; AdminLegalController .cs:21	společnost	střední	→ R3

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Tick na objednavce neobnoví odvolaný souhlas: AssertedOrAlreadyCon sentedAsync ho přijme, OrderBookingEvidenc e zaznamená, UserConsents se nepíše	CreateOrder.cs:320- 325; CreateOrder.cs:1115- 1116	společnost	střední	→ R3
MarketingEmails bez čtenáře v AppServices; marketingový push čte jen Promo	grep -rn "MarketingEmails" src/Cleansia.Core.App Services → 0; SendSitewidePromoF anoutHandler.cs:104	zákazník	vysoká	→ R9
Fan-out kampaně nefiltruje profil: úklidník s Promo = true dostane zákaznický marketing	SendSitewidePromoF anoutHandler.cs:103- 109	úklidník	střední	filtr profilu ve fan- outu
Komentář IStripeConfig tvrdí, že GdprDeletionService maže Stripe Customer; kód volá jen RemoveForUserAsync na lokální id	IStripeConfig.cs:30; GdprDeletionService. cs:529-530	zákazník	střední	→ R9
RecordAsync ukládá surové tělo RawBody (fronta SendEmail nese adresu a živý kód) bez retence	DeadLetterStore.cs:20 -25; rg -n "DeadLetter" src/Cleansia.Core.App Services/Features/Dat aRetention/PruneOut box.cs → 0	zákazník / úklidník	střední	retenční okno DeadLetters
Export zákazníka obsahuje ResolutionNotes administrátora a IpAddress + UserAgent souhlasů	GdprExportService.cs: 176; GdprExportService.cs: 135-137	společnost	nízká	rozsah exportu

4. Odolnost a provoz

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Dead letters nikdo nečte: <code>DeadLetter</code> v admin kontrolerech 0, repozitář jen <code>RemoveForSubjectAsync</code>	<code>rg -n "DeadLetter" src/Cleansia.Web.* / Controllers → 0; DeadLetterRepository.cs:20</code>	společnost	střední	admin čtenář <code>DeadLetters</code>
Outbox po 10 pokusech (backoff $30s \times 2^n$) označí <code>Failed</code> a dead-letteruje; jediná signalizace <code>LogError</code>	<code>OutboxDrainerService.cs:79-86; OutboxDrainerConfig.cs:14-15</code>	všichni	střední	alert na <code>Failed</code>
Alerty hlídají <code>HealthCheckStatus</code> , latenci, PostgreSQL a poison fronty (<code>threshold: 0</code>); pravidlo pro outbox <code>Failed</code> a databázové dead letters chybí	<code>alerts.bicep:139; queueAlerts.bicep:96</code>	společnost	střední	alert na stav outboxu a dead letters
Jediným kanálem poplachu je <code>emailReceivers</code> jedné skupiny; poison fronta hlásí <code>GreaterThan</code> práh 0, tedy každou zprávu	<code>alerts.bicep:66-72; queueAlerts.bicep:93-96</code>	společnost	střední	SMS/pager kanál
Seed PRO nenaplní: <code>SeedDevelopmentData</code> jen pod <code>IsDevelopment</code> , <code>insert_seed_data.sql</code> 1 proti PRO workflow odmítá; katalog plní admin příkazy, <code>Tenants</code> zapisovač nemá	<code>CleansiaStartupBase.cs:242; execute-sql.yml:49-58</code>	společnost	vysoká	→ R2

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Kredit CleanerNoShow píše automaticky jen CancelUnfilledOrders (prázdná posádka, registrovaný zákazník), ručně administrátor; nedostavení přiřazeného úklidníka automatickou cestu nemá	CancelUnfilledOrders.cs:299-302; issue-credit-dialog.component.ts:97-101; git grep CreditTransactionReason.CleanerNoShow src mimo testy → 3: běh, admin dialog, admin zobrazení	zákazník	střední	→ R15
SendRecurringOrderReminders vyzve k potvrzení každý výskyt s PaymentStatus.Pending, i hotovostní s uloženým RequiredEmployees > 1, který ConfirmRecurringOrder odmítne	SendRecurringOrderReminders.cs:50-56; ConfirmRecurringOrder.cs:115-116	zákazník	nízká	přípomínka jen potvrditelným výskytům
Přeskočenou hotovostní šablonu materializátor jen zaloguje (LogWarning); zákazník vidí jen stav RequiresPaymentMethodChange v seznamu, push ani e-mail nedostane	MaterializeRecurringBookingTemplate.cs:262-269; GetMyRecurringBookings.cs:68-69	zákazník	střední	→ R18
Jediný region weu → westeurope; prod parametry „AUTHORED, NOT DEPLOYED“	main.bicep:224-227; weu.prod.bicepparam:3	společnost	střední	nasazení PRO
Nenasazená konfigurace PRO určuje 35denní geo-redundantní zálohu a ZoneRedundant; v deploy není postup obnovy	weu.prod.bicepparam:56; weu.prod.bicepparam:58	společnost	střední	postup obnovy
Provozní runbook jen pro DEV (787 řádků); PRO posture 196 řádků bez incident/on-call postupu	AZURE-DEV-RUNBOOK.md:1; rg - in "incident on-call" deploy/AZURE-PROD-POSTURE.md → 0	společnost	střední	→ R10

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Jediný poskytovatel bez záložního: SendGrid (e-mail), FCM (push, no-op bez tajemství), Stripe, Mapbox (geokódování)	SendGridClientFactory.cs:16; MapboxGeocodingService.cs:14-16	všichni	střední	záložní poskytovatel e-mailu
PeriodReminderBackgroundService bez dedup razítka (čte GetQueryableIgnoringTenant, nic nezapisuje); opakovaný běh pošle e-mail znovu	PeriodReminderBackgroundService.cs:49-55	úklidník	střední	razítko odeslání
Odchod úklidníka zákazníkovi oznámení neposílá; administrátorské storno nesděljuje důvod, ale úspěšná vratka registrovanému posílá order.refunded	DropOrder.cs:165; PlatformOrderCancellation.cs:97	zákazník	vysoká	→ R18
Reklamacie oznamuje pouze úspěšnou vratku (OrderRefunded); odmítnutí účtu nemá vlastní zprávu, odebrané zakázky hlásí NotifyCleanerOfRevocationAsync	ResolveDispute.cs:118; RejectEmployee.cs:167	zákazník / úklidník	střední	→ R18
ReportOrderIssue.Handler nikoho neupozorní (jen IOrderRepository a IOrderAccessService, žádný notifikátor)	ReportOrderIssue.cs:42-44	zákazník / společnost	střední	→ R10
E-mailly Confirmed/Started/Completed (EmailService, typ 6 bez seedu, bez per-locale defaults) jdou anglicky každému jazyku	EmailService.cs:397-412; grep -n "true, 6, "" sql-scripts/insert_seed_data.sql → 0	zákazník	střední	lokalizace e-mailů

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Produkční Customer Mobile host posílá reset hesla na <code>partner.cleansia.cz</code>	<code>appsettings.Production.json:30-31</code>	zákazník	střední	oprava URL
Vývojová fixtura zakládá administrátora <code>admin@cleansia.local</code> se známým heslem <code>Admin123!</code> ; čte se jen uvnitř <code>IsDevelopment</code>	<code>insert_seed_data.sql:1891;</code> <code>CleansiaStartupBase.cs:223</code>	společnost	nízká	jiné heslo mimo DEV

5. Mobilní aplikace

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Uvolnění místa (<code>DropOrder</code>) a žádost o zástup (<code>RequestCover</code>) nese partnerský webový i mobilní host; žádná aplikace je nevolá	<code>OrderController.cs:240-271;</code> <code>OrderController.cs:285-317;</code> volání <code>DropOrder</code> ani <code>RequestCover</code> v partnerském webu, Android a iOS mimo generované klienty (<code>rg -i</code>) → 0	úklidník	střední	→ R10
Prázdná nástěnka partner iOS (<code>dash_no_jobs_yet_subtitle</code> , <code>L10n.Dashboard.noJobsYetSubtitle</code>) říká „update your availability“; obrazovka dostupnosti neexistuje	<code>Localizable.xcstrings:3589-3601;</code> <code>DashboardView.swift:323</code>	úklidník	nízká	text bez odkazu na dostupnost
Google Pay (<code>GooglePayConfiguration</code>) v Android <code>PaymentSheet</code> ; Apple Pay na iOS 0	<code>BookingBottomSheet.kt:598-607;</code> <code>rg -n "applePay PKPayment" src/cleansia_ios</code> → 0	zákazník	nízká	Apple Pay v <code>PaymentSheet</code>

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
8 push událostí bez kategorie (<code>GetCategoryFor</code> → <code>null</code>) nelze vypnout: <code>OrderAssigned</code> , <code>ReminderSoon</code> , <code>InvoicePaid</code> , <code>EmployeeWeeklyLimits</code> et ...	<code>NotificationEventCatalog.cs:226-251</code>	úklidník	nízká	→ R9
Kategorie <code>NewJobsAvailable</code> vypnutelná, ale žádný partnerský endpoint (<code>UpdateNotificationPreferences</code>) ji úklidníkovi nenastaví	<code>NotificationEventCatalog.cs:247-249</code> ; <code>rg -rn "UpdateNotificationPreferences"</code> <code>src/Cleansia.Web.Partner</code> <code>src/Cleansia.Web.Mobile.Partner</code> → 0	úklidník	nízká	endpoint preferencí pro úklidníka
Bez certificate pinningu, root/jailbreak detekce a biometrie (Android i iOS 0); tokeny v <code>EncryptedSharedPreferences</code> (Android), Keychain (iOS)	<code>rg -n "CertificatePinner SecTrustEvaluate RootBeer Jailbreak BiometricPrompt LAContext"</code> <code>src/cleansia_android</code> <code>src/cleansia_ios</code> → 0; <code>TokenStore.kt:44-54</code>	zákazník / úklidník	nízká	pinning; biometrický zámek
Android posílá souřadnice zařízení na <code>api.mapbox.com</code> s <code>access_token</code> , který je v APK jako <code>MAPBOX_ACCESS_TOKEN</code>	<code>ReverseGeocodingService.kt:28-33</code> ; <code>build.gradle.kts:54-57</code>	zákazník / úklidník	střední	→ R9

6. Web

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Před souhlasem se načítají Google Fonts (<code>fonts.googleapis.com</code> , <code>fonts.gstatic.com</code>) — IP návštěvníka odchází Googlu	<code>index.html:22-23</code> ; <code>index.html:43-49</code>	zákazník	střední	→ R9

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Cookie „analytics“ se u přihlášeného mapuje na <code>ConsentType.DataProcessing</code> , „marketing“ na <code>MarketingEmails</code> — cookie klik uděluje/odvolává e-mailový souhlas	<code>consent-sync.service.ts:36-41</code>	zákazník	vysoká	→ R9
Úklidník přihlášený v zákaznickém webu (<code>JwtAudiences.Customer</code> přijímá každý profil) odmítnutím cookies volá <code>withdrawConsent</code> na <code>DataProcessing</code>	<code>consent-sync.service.ts:46-50</code> ; <code>TokenService.cs:93</code>	úklidník	vysoká	→ R9
Žádný analytický tag neexistuje; banner (<code>categories</code>) přesto nabízí analytics/marketing/preferences	<code>rg -in "gtag googletagmanager clarity hotjar" src/Cleansia.App/apps/cleansia.app → 0</code> ; <code>cleansia-cookie-consent.component.ts:88-109</code>	zákazník	nízká	→ R9
Souhlas anonymního návštěvníka jen v <code>localStorage</code> , bez serverového záznamu	<code>cleansia-cookie-consent.component.ts:167-172</code>	zákazník	nízká	→ R9
Okno rezervace 08:00–20:00 vynucují jen klienti (<code>FIRST_WINDOW_HOUR</code> , Android); server konstanty <code>FirstWindowHour</code> / <code>LastWindowHour</code> nečte	<code>booking-window.models.ts:11</code> ; <code>BookingPolicy.cs:43-44</code>	společnost	střední	serverová validace okna
Odebrání bodů (<code>RevokePoints</code>) sniží stupeň bez oznámení; událost existuje jen pro povýšení	<code>LoyaltyAccount.cs:114-120</code> <code>RecomputeTier</code> ; <code>NotificationEventCatalog.cs:18</code> <code>LoyaltyTierUpgrade</code> ; <code>git grep -i -E "TierDown TierChanged" src → 0</code>	zákazník	střední	→ R17

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Web (welcome_express_after_trial) slibuje zkušebnímu členovi kratší storno okno; nárok (TrialEndsAtUtc) trial vyklučuje a trial založit nelze (→ PROVOZ \$9)	en.json:1462; UserMembershipRepository.cs:45	zákazník	nízká	→ R4

7. Dluh

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
OrderStatus.Pending nemá zapisovač, ale klienti a historická data jej nesou a výmaz jej počítá jako blokuující	OrderStatus.cs:22; GdprDeletionService.cs:214; git grep OrderStatus.Pending src/*.cs mimo testy → jen seznamy stavů a odmítnutí cíle v AdminOverrideOrderStatus	společnost	střední	životní cyklus historických stavů
PaymentStatus.Disputed a RefundStatus.Failed nemají zapisovač; klienti a historická data jejich číselné hodnoty přijímají	PaymentStatus.cs:12; RefundStatus.cs:10; git grep src/*.cs mimo testy: PaymentStatus.Disputed → jen seznam v OrderRepository , RefundStatus.Failed → 0	společnost	střední	životní cyklus historických stavů
ContractStatus.Active a Terminated nemají zapisovač; čtenáři je rozlišují	ContractStatus.cs:9-10; Employee.cs:318-320; git grep src/*.cs mimo testy: Active a Terminated → jen čtení, UpdateContractStatus bez volajícího	společnost	střední	→ R10

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
BookingPolicy.CalculateCancellationFeeRate nemá produkční volající; storno i náhled počítají přes CancellationAssessor a ClassifyCancellation	git grep -n "CalculateCancellationFeeRate(" src mimo testy → jen deklarace; BookingPolicy.cs:320; CancellationAssessor.cs:50	společnost	nízká	odstranění metody
Operátora trhu nastavuje jen AssignOperator bez produkčního volajícího; OperatorTenantId tak zapisuje pouze seed	grep -rn "AssignOperator(" src --glob "*.cs" → 0 mimo testy; CountryConfiguration.cs:189-191	společnost	nízká	→ R2
Sloupce Order.TravelDistance a EmployeePayConfig.DistanceRatePerKm nemají aplikačního zapisovače ani čtenáře; nenulovou uloženou sazbu administrace nezobrazí	git grep "TravelDistance DistanceRatePerKm" src mimo testy → deklarace, mapování EF a migrate; Order.cs:108; EmployeePayConfig.cs:29	společnost	nízká	→ R23
Klienti zakládají šablonu opakování bez PreferredEmployeeId a EndsOn; hodnotu z přímého volání API úprava (UpdateSchedule) přepíše, EndsOn jen webová	RecurringBookingClient.swift:32; RecurringBookingTemplate.cs:148-150; git grep -i endsOn při založení ve třech klientech → jen nil/null/undefined, preferredEmployee v Recurring kódu klientů → 0	zákazník	nízká	odeslat stávající hodnoty
i18n bez čtenáře: components.availability 22 klíčů × 5 jazyků zákaznického webu	git grep "components.availability" -- src/Cleansia.App --include=*.ts --include=*.html → 0; en.json:1728-1729	společnost	nízká	odstranění klíčů

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Mobilní katalogy obsahují chybové klíče bez odpovídajícího serverového řetězce, například <pre>error.order.cancellation_window_closed a error_referral_self_referral</pre>	<pre>rg serverových řetězců v produkčním C# → 0; Localizable.xcstrings:3 362; strings.xml:1233</pre>	společnost	střední	revize neemitovaných klíčů
Zastaralé komentáře: RecurringBookingTemplate „No UI exists today“ (endpoint Create existuje); OrderDuration a GetMyServingCleaners odkazují na neexistující OrderDurationAgreementTests	<pre>RecurringBookingTemplate.cs:14-15; OrderDuration.cs:10; git ls-tree -r --name-only src grep OrderDurationAgreementTests → 0</pre>	společnost	nízká	oprava komentářů
Komentáře ConfirmRecurringOrder slibují stav Confirmed (hotovost okamžitě, karta z webhooku); zapisuje se jen PaymentStatus.Paid	<pre>ConfirmRecurringOrder.cs:24-25; ConfirmRecurringOrder.cs:285-286</pre>	společnost	nízká	oprava komentářů
Název společnosti na 3 místech: Tenants.Name „Cleansia CZ s.r.o.“, CompanyInfo.LegalName „Cleansia s.r.o.“, patička webu a e-mailů „Cleansia s.r.o.“	<pre>insert_seed_data.sql:6 3-64; insert_seed_data.sql:1 147-1158</pre>	zákazník / společnost	střední	→ R2